

The Crystal Ball

Where the Current Path in Digital Security Ends — and What to Do Before It Does

2026

The prevailing model of digital security is failing on a trajectory that is both predictable and preventable. This paper identifies three converging failures — the inevitable expansion of AI access to plaintext data, the accelerating political and commercial compromise of centralized data custodians, and the compounding complexity that makes catastrophic systemic failure a matter of when rather than if. These failures are not independent; they share a common root: the treatment of users as subjects of security rather than agents of their own security. The paper examines this root, addresses the common objections to the alternative, and argues that a decentralized, user-sovereign model is not only possible but already operational. The future is not determined. It is a design choice.

I. The Prediction Business

Predicting the future of technology is generally a fool's errand. The specific form of what comes next is unknowable. But the consequences of structural decisions — decisions already made, baked into systems deployed at global scale — follow trajectories. And some of those trajectories are readable.

This paper is not about predicting breakthroughs. It is about reading trajectories. Specifically, it reads three structural trajectories in digital security that are already in motion, identifies where they intersect, and names what the intersection produces if the current path continues. It then names what changes if we choose a different path.

The conclusion will not be comfortable for the security industry as currently constituted. It is, however, actionable. The choice of path remains available. It will not remain available indefinitely.

II. Three Converging Failures

Failure One: AI Will Eventually Access Everything It Can Reach

Artificial intelligence — and in particular the agentic AI now being deployed at scale across enterprise and consumer environments — operates on a simple principle: it processes what it can access. The capabilities of these systems grow continuously. The authorization frameworks governing what they can access have not kept pace.

The practical consequence is not subtle. An AI agent acting on behalf of a user, or on behalf of an organization, will eventually be in a position to access plaintext data, administrative credentials, and the full breadth of information available to a sufficiently privileged identity. This will happen through three distinct mechanisms, and they do not always require malicious intent.

The first mechanism is attack. Agents hold delegated credentials. Credentials are targets. A compromised agent is a compromised identity, and a compromised identity with administrative reach is a catastrophic event by any measure. This is not a novel attack surface; it is a familiar one operating at a new scale.

The second mechanism is hallucination. Large language models produce confident outputs from ambiguous inputs. An agent instructed to retrieve a document may retrieve the wrong one. An agent instructed to summarize may include content it was never supposed to surface. These are not theoretical failure modes; they are documented behaviors of current production systems.

The third mechanism is scope drift. Agents are goal-directed. An agent given broad access and a complex goal will explore that access in service of the goal. It will read what it can read. It will act on what it can act upon. Over time, “what it can reach” expands as delegated permissions accumulate. There is no natural limit to this expansion under the current model.

The question is not whether AI will access data you did not intend it to access. The question is whether you will have designed for that inevitability when it arrives.

What amplifies this beyond individual incidents is the agentic chain. Modern AI deployments are not single-agent systems. They are pipelines — agents calling agents, each delegating a fragment of their authorization to the next link in the chain. The blast radius of any single compromise in this chain is not linear. It is

exponential. An agent near the top of the chain with broad permissions acts as a force multiplier for every vulnerability further down.

There is no organizational response to this at scale that does not require rethinking what AI agents are permitted to access in the first place. Patching individual agents is whack-a-mole. The structural response is to constrain what plaintext exists to be accessed.

Failure Two: Centralized Custodians Are Being Squeezed Against Users

The second failure is not technical. It is political and economic, and it is already fully underway.

The model of centralized data custody — in which a single entity holds vast quantities of user data, credentials, and behavioral records on behalf of many millions of individuals — creates an asset that is irresistible to two forces: commercial interests seeking to monetize it, and governmental interests seeking to control access to it.

Neither of these forces is hypothetical. Both are active today. The pattern is consistent across jurisdictions and platforms: data held in centralized custody is gradually repurposed away from the interests of the people it was collected to serve.

This happens through several mechanisms. Legislative and regulatory pressure compels disclosure. Intelligence gathering proceeds through legal instruments that preclude notification to the data subject. Commercial logic continuously tests the boundary between “serving users” and “monetizing users,” and pressure from shareholders reliably moves that boundary in one direction.

The common feature of each mechanism is that the entity holding the data wins regardless of outcome. If it complies with a government request, it continues operating. If it monetizes user data, it grows revenue. If it suffers a breach, it pays a fine and continues operating. The user, in every scenario, absorbs the harm. A year of credit monitoring is not compensation for a lifetime of exposed medical history.

Liability without vested interest is not accountability. It is a tax on failure, paid by the wrong party.

The regulatory response to this failure has paradoxically entrenched it. Compliance regimes like GDPR and its successors are genuinely expensive. For large, well-resourced platforms, compliance cost is a manageable operational expense — and, more importantly, a barrier to entry that protects their market position. The entities most capable of absorbing compliance cost are precisely the entities that have accumulated the most data, which are precisely the entities the regulation was meant to constrain. The regulatory ratchet, however well-intentioned, has become a moat.

Meanwhile, the fiction of informed consent — the bedrock legal justification for centralized data custody — has collapsed in practice. Privacy policies are legally binding contracts that no ordinary person reads, understands, or has any meaningful ability to negotiate. Both parties to this fiction are aware it is a fiction. The legal framework proceeds regardless, because no one with the power to change it has a sufficient incentive to do so.

Failure Three: The Complexity Trap Guarantees Catastrophic Failure

The third failure follows from the first two. When AI access risks cannot be contained at the data layer, the response is access controls — more granular, more numerous, more complex. When centralized custody cannot be made trustworthy through incentive alignment, the response is process — more audits, more certifications, more compliance frameworks. These responses are not wrong. They are insufficient.

Each layer of access control interacts with every other layer. Each compliance framework introduces new data requirements, new logging surfaces, new integration points. The aggregate system becomes opaque to the people responsible for operating it. This is not a failure of execution. It is a structural property of systems that grow by accretion.

The software supply chain adds a dimension that access controls are entirely unable to address. Zero-trust architectures verify identities and access continuously — but they cannot verify the integrity of every dependency in the software stack. A compromised component arrives with valid credentials, passes every check, and is trusted by the framework meant to prevent exactly this. A backdoored compression library, a compromised build pipeline, a malicious package in a widely-used registry — each is indistinguishable from the legitimate code it replaced.

And layered beneath all of it: the harvest-now-decrypt-later problem. Centralized encrypted data stores are being systematically exfiltrated today against the post-quantum transition. The ciphertext being collected is opaque now. It will not remain opaque. Data that cannot be retroactively protected must be protected prospectively — which means it must either not exist in centralized form, or it must be assumed to be already in adversary hands.

The trajectory of this complexity leads to one place: a system so interlocked, so opaque, and so broadly depended upon that a single sufficiently large failure cascades across the entire surface. This is not pessimism. It is the documented behavior of complex systems under stress, applied to a digital infrastructure that now underlies most of modern economic and social function.

III. The Common Root

These three failures are distinct in mechanism but identical in origin. Each is a consequence of a single design decision, made so early and so universally that it has become invisible: the decision to design security for institutions, and then explain to users why they must comply with it.

Under this model, the user is not an agent. The user is a subject — someone to whom security happens, rather than someone who exercises security. The user is managed, enrolled, provisioned, and deprovisioned. Their credentials live in someone else's store. Their data is held by someone else under someone else's terms. Their consent is obtained through a legal instrument they did not meaningfully consent to.

The system was never designed to protect users. It was designed to serve institutional needs, then retrofitted with user-facing justifications.

Every failure described in the preceding section flows directly from this design posture. AI agents access plaintext because the data is centrally held in a form accessible to privileged identities — and agents inherit privileged identities. Centralized custodians are squeezed against users because the user's interest was never the design center; it was a constraint. Complexity compounds because each patch to the system is designed to protect institutional interests and simply creates new surface for the next patch.

If this diagnosis is correct, then the solution is not a better patch. It is a design inversion.

IV. The Objections, Answered

Two objections to the alternative model appear with sufficient regularity that they deserve explicit treatment. Both are wrong, but both are persuasive, which means they need to be addressed on their own terms.

Objection One: Ordinary People Cannot Manage Their Own Security

This is the most common objection, and it carries the most intuitive weight. People reuse passwords. They click phishing links. They lose devices and forget recovery codes. The entire justification for centralized security management rests, in significant part, on the observation that users are demonstrably bad at security.

The observation is accurate. The conclusion drawn from it is not.

The users described above are not failing at security. They are failing at security as it was designed — which is to say, they are failing at systems that were never designed around them. The password is a mechanism optimized for system administrators. The recovery code is a mechanism optimized for the assumption that users have safe storage for cryptographic material. The phishing link exploits a trust model that was designed for institutional actors and layered onto human psychology as an afterthought.

When security is designed from the user's perspective — when the question asked is not “how do we make users comply with our security model” but “what does security look like when it works for the person using it” — the results are qualitatively different. Users do not fail at security because they are incapable. They fail at security because they are being asked to operate systems that were not designed for them.

The argument that users are incapable is not a neutral observation. It is a design failure that has been laundered into a justification for the failure. Naming this dynamic is important, because the alternative model is explicitly rejected by its opponents on the grounds that ordinary users cannot be trusted with sovereignty over their own data — a position that forecloses the solution by embedding the problem in the premise.

Objection Two: Decentralization Already Failed (The Web3 Argument)

The second objection reaches for the pattern-match: decentralization, user sovereignty, eliminating the custodial middleman — this is the promise that drove a decade of blockchain and Web3 development, and it largely produced unusable tools, speculative excess, and a generation of lost wallets.

The pattern-match is understandable. The conclusion is wrong, for a simple reason: the Web3 movement was not a user-sovereignty project. It was a financial speculation project with user-sovereignty rhetoric attached to it. The design center was not the ordinary person trying to safely manage their identity and data. It was the early adopter with tolerance for complexity, appetite for financial risk, and sufficient technical sophistication to navigate systems that were never going to work for anyone else.

User-sovereign security rooted in identity and access — designed with usability as a first-class constraint, not a secondary consideration — is a categorically different undertaking. The cryptographic primitives are the same. The design philosophy is opposite.

The Web3 comparison is worth making explicit in order to set it aside cleanly: the failure of a poorly-designed decentralized financial speculation system tells us nothing about the viability of a well-designed decentralized identity and security system. Confusing them is like arguing that the failures of early automobile design prove that personal transportation is unworkable.

V. What the Alternative Looks Like

The alternative to the current model rests on three structural changes, each of which is a direct inversion of the current design posture.

Decentralize Risk

Data that is not aggregated cannot be harvested at scale. Credentials that do not exist in a centralized store cannot be breached from a centralized store. An AI agent that operates against a cryptographic vault it cannot read directly cannot exfiltrate plaintext regardless of its level of access.

This is not a new principle. It is the core argument for end-to-end encryption applied to the full surface of user data and identity, not just message content. The

implementation challenge is real. The principle is sound, and the technology to execute it exists.

Design for the User, Not for the Institution

Every decision in the security stack — credential management, authentication flow, recovery, agent authorization — should begin with the question: does this work for an ordinary person? Not “can we train an ordinary person to operate this,” but “does this actually work for someone who has not been trained, is not a specialist, and has better things to think about than their security architecture?”

This is a different design question than the field has historically asked. It produces different answers. It does not produce simpler security; it produces security where the complexity is absorbed by the system rather than transferred to the user.

Move Liability to the Party with Vested Interest

The current liability model assigns legal accountability to whoever holds the data. This is sensible in principle but perverse in practice, because the entity holding the data profits from holding it, is positioned to limit its legal exposure through counsel and insurance, and continues operating after a breach. The user bears the actual harm with essentially no leverage.

The correct principle is that liability should follow vested interest. An entity that does not hold data cannot be compelled to betray it, cannot be breached for it, and bears no legitimate legal exposure for it. This is not a loophole. It is the appropriate alignment of incentive and accountability. The entity best positioned to protect the user’s data is the user, because the user is the only party whose interests are fully aligned with protecting it.

Making this work requires that the user be provided with tools adequate to the responsibility. This returns to the design question: what does sovereign data management look like when it is designed to succeed, rather than designed to demonstrate that it cannot?

VI. This Is Not a Future Problem

Each failure described in this paper is already in motion. The AI access problem is not a prediction about systems that do not yet exist; it is a description of systems deployed now, in production environments, with authorization

frameworks that have not kept pace with capability. The political and commercial compromise of centralized custodians is not a risk; it is a documented, ongoing pattern. The complexity trap is not approaching; organizations are already operating security architectures whose full interaction surface no individual understands.

More importantly: the alternative is not a future possibility. A decentralized, user-sovereign identity and security architecture is not a research project. It is operational today. The cryptographic primitives are mature. The architectural patterns are understood. The implementation exists.

The crystal ball does not predict doom. It predicts the continuation of a present failure, and the availability of a present solution that the industry has not yet chosen to adopt.

The choice is not between a broken present and an ideal future. It is between a broken present that continues on its current trajectory, and a different present that changes the trajectory. The window for making that choice is open. It will not remain open indefinitely. As AI capabilities expand, as centralized data stores accumulate more irreplaceable personal information, and as the complexity of current architectures increases, the cost of transition rises and the risk of a transition-forcing catastrophe rises with it.

There is no mystery about where the current path leads. The crystal ball is not cloudy. The fog is a choice.

VII. A Note on Timing

The harvest-now-decrypt-later problem deserves specific attention as a timing constraint. Nation-state actors and well-resourced adversaries are not waiting for the quantum transition to begin collecting encrypted data. They are collecting it now, at scale, with the explicit intention of decrypting it when the cryptographic assumptions underlying current public-key infrastructure fail.

The timeline on post-quantum cryptographic readiness is measured in years to a decade, depending on adversary resources and the specific algorithm families under consideration. The data being collected today — medical records, financial history, identity credentials, personal communications — has a relevance horizon measured in decades. The intersection of these two timelines is not comfortable.

Data that is never centralized cannot be retroactively harvested. This is the structural argument for decentralization that has nothing to do with current threat actors and everything to do with the permanent record being assembled against a future capability. Every year of continued centralized aggregation is another year of material being added to that record.

VIII. The Call

This paper began with three predictions. It ends with one.

The current path — centralized custody, institutional security design, liability frameworks misaligned with harm, AI agents operating against aggregated plaintext, complexity compounding faster than it can be managed — ends in a failure large enough to be visible from here. The exact shape of that failure is not predictable. That it will occur, absent a change of direction, is not a forecast requiring extraordinary confidence. It is arithmetic.

The alternative path is available. It requires designing security for the person it is meant to protect. It requires distributing risk rather than aggregating it. It requires moving accountability to the party with a genuine stake in the outcome. It requires treating the user not as a problem to be managed but as the principal whose interests the entire system exists to serve.

None of this requires technology that does not exist. None of it requires a leap of faith. It requires a decision.

The question is not whether the current model will fail. The question is whether we choose a different model before it does.

The tools are built. The architecture is understood. The path is clear. What the field has not yet decided is whether it will choose a future it can build, or wait for a future it cannot avoid.